Jr.Pen 1. Cyber Security Journey

1. Offensive Security Intro

Task 1 - Think like a Hacker!

Offensive Security is about thinking like an attacker to find weaknesses before real hackers do. In this room, you'll hack your first website in a safe and legal environment to see how ethical hackers operate.

Answer the questions below

> Which term describes simulating a hacker's actions to find weaknesses?

Offensive Security

Task 2 - Starting the Lab

This room uses a virtual desktop to simulate a real system. A browser will automatically open, displaying FakeBank, a fake banking application. This is what you will be targeting.

Answer the questions below

> What is the bank account number in the FakeBank application? 8881

Task 3 - Find Hidden Pages

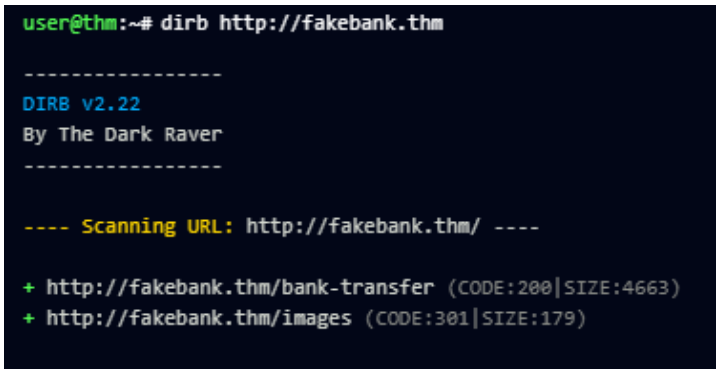
Open the terminal on the machine. You will be using this to run your first hacking tool, `dirbuster`. To find hidden pages using Dirbuster, we will use `dirb` and the URL that we wish to search:

```
dirb http://fakebank.thm
```

Answer the questions below

> What is the other hidden URL?

http://fakebank.thm/bank-transfer



Task 4 - Attack the Admin Page

You should now have found a hidden admin panel that lets you add money to your account. To open this URL in the browser of the simulated desktop add /bank-transfer to the URL in the browser. Use your account number **8881** and deposit **$2000** (or more). After depositing, return to your account page and confirm the balance is now positive.

Answer the questions below

> When your balance turns positive, a pop-up with green text appears.

BANK-HACKED

2. Defensive Security Intro

Task 1 - Think like a Defender



Defensive security is the process of defending and securing devices and systems. Before you can defend a system, you need to understand what defenders are responsible for. Defensive security focuses on detecting and investigating attacks, and responding before damage occurs. Unlike offensive security, you do not attack systems, instead, you monitor and protect them.

Answer the questions below

> What is the main goal of defensive security?

Detect and respond to attacks

Task 2 - Detect Suspicious Activity

Joe is an apprentice SOC analyst on his first solo shift. A moment ago, his monitoring dashboard lit up - something doesn't look right. Real SOC analysts rely on tools like this every day to separate normal activity from suspicious behaviour, and right now Joe needs your help to investigate before it becomes a serious incident.

Monitoring tools such as the one you'll be using provide insights as to what activity is taking place on computing devices. Defenders use tools like this dashboard to make sure that all activity taking place on these systems is legitimate, and investigate activity that is suspicious.

Answer the questions below

> Which source IP address is generating the suspicious traffic?

32.122.195.63

Task 3 - Identify the Attack

Joe has spotted the suspicious activity, but knowing something is wrong is only half the battle. He now needs to figure out what the attacker is actually trying to do. Help Joe dig into the data and work out what kind of attack is underway before the attacker finds what they're looking for.

1. Investigate the attack that has occured.

2. View the "URL Discovery Attempts" list.

3. Look at the latest "URL Discovery Attempts" entry to answer the question.

The monitoring dashboard shows a history of what the attacker is trying to find on our website. You will see that the dashboard has captured the attacker trying many attempts to access hidden pages, very quickly. Once we know what the attacker is trying to achieve, we can then begin to take measures to stop the attacker and then finally fix the problem that allowed this attack in the first place.

Answer the questions below

> Copy the latest URL that the attacker has tried to find and paste it below.

https://fakebank.com/admin

Task 4 - Stop the Attack

Joe knows who the attacker is and what they're trying to do. Now it's time to act. In defensive security, the immediate priority is **containment** (stopping the attack while it's happening) to protect the organisation. For this stage of the practical, Joe has already completed some security updates, but needs your help to complete the last.

1. Review the security actions. Joe has done two of these for you.

2. Block the attacker's IP address below by adding it into the "Add Firewall Rule" textbox on the practical. **32.122.195.63**

3. Make sure to select "**BLOCK**" from the dropdown and press "Apply".

Now that we know who the attacker is and what they're attempting, we can stop them. The immediate priority in defensive security is containment to protect the organisation. We can investigate the finer details and fix any vulnerabilities after.

This monitoring tool lets you implement several measures to stop the attacker:

- **Blocking the IP address:** Prevents the attacker's device from accessing our systems entirely. A good immediate step.
- **Applying Rate Limiting:** Limits the number of connections possible in a given time for everyone. Effective here because the attacker was rapidly accessing many pages at once, potentially overwhelming our systems.
- **Updating Security Rules:** Tightens access controls to sensitive pages that the attacker was able to slip through.

Answer the questions below

> When the success message appears, copy the flag and paste it below.

THM{FAKEBANK-SECURED}

3. Search Skills

Task 1 - Introduction

A quick Google search for “learn cyber security” returned around 600 million hits, while a search for “learn hacking” returned more than double that number!

Task 2 - Evaluation of Search Results

- **Source**: Identify the author or organization publishing the information. Consider whether they are reputable and authoritative on the subject matter. Publishing a blog post does not make one an authority on the subject.
- **Evidence and reasoning**: Check whether the claims are backed by credible evidence and logical reasoning. We are seeking hard facts and solid arguments.
- **Objectivity and bias**: Evaluate whether the information is presented impartially and rationally, reflecting multiple perspectives. We are not interested in authors pushing shady agendas, whether to promote a product or attack a rival.
- **Corroboration and consistency**: Validate the presented information by corroboration from multiple independent sources. Check whether multiple reliable and reputable sources agree on the central claims. Answer the questions below

> What do you call a cryptographic method or product considered bogus or fraudulent?`

Snake oil

> What is the name of the command replacing netstat in Linux systems?

ss

Task 3 - Search Engines

Let’s consider the search operators supported by Google.

- `"exact phrase"`: Double quotes indicate that you are looking for pages with the exact word or phrase. For example, one might search for `"passive reconnaissance"` to get pages with this exact phrase.
- `site:`: This operator lets you specify the domain name to which you want to limit your search. For example, we can search for success stories on TryHackMe using `site:tryhackme.com success stories`.
- : The minus sign allows you to omit search results that contain a particular word or phrase. For example, you might be interested in learning about the pyramids, but you don't want to view tourism websites; one approach is to search for `pyramids -tourism` or `tourism pyramids`.
- `filetype:`: This search operator is indispensable for finding files instead of web pages. Some of the file types you can search for using Google are Portable Document Format (PDF), Microsoft Word Document (DOC), Microsoft Excel Spreadsheet (XLS), and Microsoft PowerPoint Presentation (PPT). For example, to find cyber security presentations, try searching for `filetype:ppt cyber security`.

> How would you limit your Google search to PDF files containing the terms cyber warfare report?

filetype:pdf cyber warfare report

> What phrase does the Linux command ss stand for?

socket statistics

Task 4 - Specialized Search Engines

SHODAN It allows you to search for specific types and versions of servers, networking equipment, industrial control systems, and IoT devices.

CENSYS Shodan focuses on Internet-connected devices and systems, such as servers, routers, webcams, and IoT devices. Censys, on the other hand, focuses on Internet-connected hosts, websites, certificates, and other Internet assets.

VirusTotal VirusTotal is an online website that provides a virus-scanning service for files using multiple antivirus engines. It allows users to upload files or provide

URLs to scan them against numerous antivirus engines and website scanners in a single operation.

Have I Been Pwned Have I Been Pwned (HIBP) does one thing; it tells you if an email address has appeared in a leaked data breach.

> What is the top country with lighttpd servers?

United States

> What does BitDefenderFalx detect the file with the hash 2de70ca737c1f4602517c555ddd54165432cf231ffc0e21fb2e23b9dd14e7fb4 as?

Android.Riskware.Agent.LHH

Task 5 - Vulnerabilities and Exploits

CVE It provides a standardized identifier for vulnerabilities and security issues in software and hardware products. Each vulnerability is assigned a CVE ID with a standardized format like CVE-2024-29988. This unique identifier (CVE ID) ensures that everyone from security researchers to vendors and IT professionals is referring to the same vulnerability, CVE-2024-29988 in this case.

The MITRE Corporation maintains the CVE system. For more information and to search for existing CVEs, visit the CVE Program website.

Exploit Database The Exploit Database lists exploit codes from various authors; some of these exploit codes are tested and marked as verified.

GitHub, a web-based platform for software development, can contain many tools related to CVEs, along with proof-of-concept (PoC) and exploit codes. T

> What utility does CVE-2024-3094 refer to?

xz

Task 6 - Technical Documentation

Linux Manual Pages: We issue the command man ip. You might want to start the AttackBox and run man ip on the terminal. If you prefer to read the man page of ip in your web browser, just type man ip in your favourite search engine. This page might be at the top of the results.

Microsoft Windows: Microsoft provides an official Technical Documentation page for its products.

> What does the Linux command cat stand for?

concatenate

> What is the netstat parameter in MS Windows that displays the executable associated with each active connection and listening port?

-b

Task 7 - Social Media

Social media offers a wealth of information for cyber security professionals, whether they are searching for people or technical information.

> You are hired to evaluate the security of a particular company. What is a popular social media website you would use to learn about the technical background of one of their employees?

LinkedIn

> Continuing with the previous scenario, you are trying to find the answer to the secret question, “Which school did you go to as a child?”. What social media website would you consider checking to find the answer to such secret questions?

Facebook